

真题



2018考研837

一. 选择 (10*2)

1. TCP/IP协议中, 网络层上一层 C位平面层

2. IP数据包最短头部或者数据包大小? (20B, 最大 60B)

信息安全 3. 互操作, 信息.....分类。 (互操作, 技术标准, 信息安全管理体系)

4. cc标准属于 措施, bs7799属于 措施。 (技术类, 管理类)

二. 填空 (10*2)

1. socket编程中需要root权限的是 编程。 raw socket (原始 socket)

2. HTTP中状态码为200表示 状态。 OK, 请求成功

3. 风险评估两个过程, 。其中全面识别风险来源的是 。 (风险评估, 风险控制, 详细评估)

三. 简答 (5*6)

1. ping的作用及其原理。

2. TCP慢启动的原理机制。

3. 距离向量路由算法的原理。

4. 公钥密码的基础是什么? 谈谈自己看法

5. ssl四个协议名称以及作用 → 记录

6. ping of Death 的原理

四. 计算 (10*2)

1. IP子网分配

2. DH算法计算

五. 论述 (15*2)

1. 若用p2p从服务器下载文件, 同时下载人数越多, 下载速度会更快吗

2. 如果设计出应用层防火墙, 能否替代入侵检测系统

六. 设计 (15*2)

1. 设计一对多网络地址转换系统, 详细说明从内到外, 从外到内的数据处理过程。

2. 针对成绩管理设计一个系统

要求: ①老师和学生拥有一个唯一的教师号或学号

②n个学生, 一个教师一门课程, s门课程, 成绩共s*n项

一个二维表: 教师和学生的自然信息

一个表: 学生的所有课程成绩

一个表: 访问控制权限管理

说明身份认证与访问控制机制

18年简答:

① 作用: 测试网络之间的连通性和延迟。

原理: ping是ICMP的一种是属于IP层的协议

ping 命令会发送一份ICMP回显请求报文给目标主机, 并等待目标主机返回ICMP回显应答。因为ICMP协议会要求目标主机在收到消息之后, 必须返回ICMP应答消息给源主机, 如果源主机在一定时间内收到了目标主机的应答, 则表明两台主机之间网络是可达的。

② 在TCP刚刚连接好并开始发送TCP报文段时, 令cwnd为1, 每收到一个对报文段的ACK便令cwnd加1, 即经过一个RTT, cwnd加倍。直到把cwnd增大到慢开始门限sssthresh。再使用拥塞避免算法。这样可使分组注入网络是速率更合理。

慢开始的慢并不是指cwnd的增长速率慢, 而是指一开始将cwnd设置为1, 再逐渐增大 cwnd。

出现三种事件会结束慢开始: 1、出现超时。2、到达慢开始门限。3、检测3个冗余ACK。

③ 距离向量算法是一种迭代的、异步的、分布式的算法。分布式: 每个节点都要从一个或多个直接相连的邻居接受某些信息, 执行计算, 然后将其计算结果分发给邻居。

迭代: 此过程一直要持续到邻居之间无更多信息要交换为止。异步: 且不要求所有节点相互之间步伐一致的操作

通常使用bellman-ford方程 $d(y) = \min\{c(x, v) + d(y)\}$, 当节点x发现其直接相连的链路开销变化 或从某个邻居接受到一个距离向量的更新时, 就更新其距离向量估计值。节点x真正需要知道的, 是沿着最短路径到y的下一跳邻居节点v。

④ 单向陷门函数 / 离散对数

⑧ 7.1 SSL记录协议

提供了保密性和消息完整性两种服务。

功能是根据当前会话状态指定的参数，对要传送的高层数据实施压缩与解压缩、加密与解密、计算与校验MAC。

五个步骤:分段、压缩、添加mac、加密、添加记录头 7.2、SSL握手协议

⑨ SSL最[?]要的部分就是握手协议。用于建立会话、协商加密方法、鉴别方法和初始化操作。使服务器和客户能相互鉴别对方的身份、协商加密等。

包括四个阶段:1、建立安全能力。2、服务器认证与密钥交换。3、客户端认证与密钥交换。4、结束

7.3 SSL转换密码规范协议

通知对方将已挂起的状态复制到当前状态中，用于更新当前连接使用的密码规范。

7.4、SSL报警协议 将SSL传输过程中的警报信息传送给对方。

① Ping of Death 原理

向受害者发送超长的icmp数据包，ip数据包最大不超过65535B，当icmp所封装的数据加上ip头和icmp头的长度超过了这个数值，接收到此数据包的主机将会出现异常。

设计题： ① 参考 NAT
② 略

《网络与信息安全基础（837）》回忆版本

一、选择题

（忽略简单题）

1、以下哪一种不是网络接入方式？

A、5G B、P2p C、HTTP D、ARP

2、业务拒绝攻击有两种，一是通过攻击_____的方式，是主机瘫痪；二是通过构造_____，使服务器不能正常提供服务？

A、网络协议、大量数据
B、应用软件，攻击数据包
C、文件系统，攻击数据包
D、网络接口、大量数据

3、入侵检测模型的过程分为信息收集、_____、响应处理

A 信息清洗 B 信息过滤 C 信息分析 D、XXXXX

二、填空题

（忽略简单题）

1、MAC 控制模型首先定义访问主体与客体的_____属性，之后对他们们的安全级别进行_____，判断是否能够访问

2、TCP 的中文名称是传输层控制协议，UDP 的中文名称是_____

3、美国关于数字签名标准是这么说的，通过使用_____与一个参数，对消息进行运算，完成对用户通信的_____进行认证。

4、BS7799 标准的定义：

采用层次结构化形式定义描述了安全策略，信息安全的组织结构等几个重要要素

三、简答题

1、简述 TCP 的四元组及其作用

2、简述 UDP 由哪四个字段构成

3、简述全为 0 的主机地址与全为 1 的主机地址的作用

4、一个密码体系的实际使用，需要满足什么特性

5、散列函数要满足什么特性

6、IPSEC 中 AH 与 ESP 认证数据的区别是什么

四、计算题

1、A、B 两主机，中间两个路由器，A---R1---R2---B，传输速率 4Mbps，每段链路长 2000 公里，传输速率为 $2.5 \times 10^3 \text{ km/s}$ ，问传输 1000 字节的数据的端到端时延

2、假设素数为 11，原根为 2，问 A 传输的 YA 为 9，问其 XA 是多少？B 传输的 YB 为 3，问两者密钥 K 是多少

五、辨析题

1、寝室中电脑能访问一些网站，而不能访问一些网站，小明认为是 DNS 服务器出问题，需要更换 DNS 服务器地址，小强认为是网站挂了，需要 ping 一下网站，你认为两人的说法争取与否，你还能想到其他原因跟测试手段吗？

2、有人说静态包过滤防火墙就是过滤静态数据包，动态包过滤防火墙就是过滤动态数据包，

你认为这个说法正确与否?

六、设计题

- 1、请设计一个小系统，满足两人在线猜拳，请写出服务器与客户端协议的设计，接收的消息类型与做的处理
- 2、请为网上医院设计一个网络注册登录过程的，满足注册与登录需要。



① TCP 四元组及其作用

四元组是：

源IP地址、目的IP地址、源端口、目的端口

五元组是：

源IP地址、目的IP地址、协议号、源端口、目的端口

七元组是：

源IP地址、目的IP地址、协议号、源端口、目的端口、服务类型以及接口索引

tcp四元组可以唯一确定一个链接，原地址和目的地址在ip报文中，是将报文发送或接收到对应主机。原端口和目的端口是tcp报文头部，用于发送给对应主机的相应进程。

② UDP

16位源端口号	16位目的端口号
16位UDP长度	16位UDP校验和
数据	

源端口：需要回信时选用，不需要时全为0

目的端口：

长度：包括前部和数据，最小为8B

校验和：可选，不校验时全为0

③

主机位全为0的时候，此IP地址表示网络号代表网络段本身，也就是本网段的代表，常用在路由器的路由表中

主机位全为1的时候，此IP地址表示广播地址，代表的是整个网段中的所有主机，即可以向该网段中的所有的主机发送数据包

④

系统即使达不到理论上不可破解，也应当在实际上不可破解的：
系统的保密性不依赖于加密体制或算法的保密，而依赖于密钥的保密：加密算法和解密算法适用于密钥空间中的所有元素：密码系统既易于实现也便手使用。

⑤ 无碰撞性：
 { 强无碰撞性：在计算上难以找到 x, y ，使 $h(x) = h(y)$
 弱无碰撞性：在特定明文空间 X 上，难以找到 x, y 。
 单向性：通过 h^{-1} 来求 $h(x)$ 的原文计算上不可行。

⑥ AH认证整个数据包，包括ip头和承载数据
ESP的认证作用范围只是承载数据，不包括ip头

计算：

① 传播时延： $2 \times 10^3 \text{ km} \times 3 / .25 \times 10^8 \text{ km/s} = 2.4 \text{ s}$

发送时延： $1000 \text{ B} = 1000 \times 8 \text{ bit}$

$$\frac{8000 \text{ b}}{4 \times 10^6 \text{ b/s}} = 2 \times 10^{-3} \text{ s}$$

$2.4 \text{ s} + 0.002 \text{ s} = 2.4002 \text{ s}$

$2 \times 10^{-3} \text{ s} \times 3 = 6 \times 10^{-3}$
 2.406 s

② $p=11$ $g=2$.

$Y_A = g^{x_A} \text{ mod } p = 9 \Rightarrow x_A = 6$

$Y_B = g^{x_B} \text{ mod } p = 3 \Rightarrow x_B = 8$

$K = g^{x_A x_B} \text{ mod } p = 2^{48} \text{ mod } 11 = [(2^6 \text{ mod } p) \cdots] \text{ mod } p$
 $= 9^8 \text{ mod } p$

$= 4^4 \text{ mod } p = 1^8 \text{ mod } p = 1$

判断题

- ① 都有可能正确，如果是DNS服务器挂掉了，则得不到网站的ip地址也就无法访问到正确的网页，可能还是在本地缓存中的错误地址。如果是网站挂掉了，即使在DNS服务器得到了正确的ip地址也访问不到正常的网站资源。

可能是arp没能得到正常的响应，访问不到mac地址；或者DNS服务器记录信息被污染，不能从DNS服务器获取正确的ip地址。

（更换网络环境使用ip地址直接访问）

- ② 错误的，静态数据包过滤是根据数据包头信息来过滤，并不只是单纯的过滤静态的数据包也可以添加和修改；而动态包过滤是基于会话，动态的建立和删除过滤规则，而不需要对整个ACL表做出改动。

补充：

静态包过滤防火墙主要依赖于对数据包网络层和传输层首部信息的判定，不对应用负载进行检查，判定信息的不足使其难以对数据包进行细致的分析。其次，包过滤防火墙的规则配置较为困难，特别是对于安全策略复杂的大型网络，如果包过滤规则配置不当，防火墙难以有效的进行安全防护。第三，包过滤防火墙支持的规则数量有限，如果规则过多，数据包依次与规则匹配，将降低网络效率。最后，由于数据包中的字段信息容易伪造，攻击者可以通过 IP 欺骗等方法绕过包过滤防火墙，而包过滤防火墙本身难以进行用户身份认证，这些因素使得攻击者可能绕过包过滤防火墙实施攻击

动态的包过滤防火墙在接收到数据包时，将以连接状态表为基础，依据配置的包过滤规则，判断是否允许数据包通过，从而更加有效地保护网络安全：动态的包过滤防火墙能够提供更全面的日志信息。

设计题:

①

现在我们把难度提高一点: 诸葛亮想和曹操猜拳, 但是两人身处异地无法见面。这种情况下如何保证公平呢?

如果诸葛亮把自己的信封用快马送给曹操, 那曹操可以拆开看到诸葛亮的出拳之后再写自己的信。所以之前的解法就失效了。信封这个解法不行了, 不过如果用一点密码学, 还是可以异地猜拳。我们假设诸葛亮有一个抵抗碰撞的哈希函数 (collision-resistant hash function) $f(x)$, 满足如下的条件:

(1) 从 x 很容易计算 $f(x)$ 。

(2) 非常难找到两个 x, y 满足 $f(x) = f(y)$ 。

诸葛亮先确定一个选择 m {石头, 剪刀, 布}。然后再选择一串随机数 r , 把自己的承诺 $y = f(r, m)$ 发给曹操。曹操同样把自己的“承诺” y' 发给诸葛亮。

诸葛亮等自己收到曹操的承诺 y' 以后, 再把随机数 r 和自己的出拳 z 发送过去。曹操等收到承诺之后, 做同样的事。

曹操通过计算 $f(r, m) = y$ 来确保诸葛亮没有作弊。

现在双方可以比较彼此的出拳, 来决定谁胜谁负! 问题是: 为什么这样可以杜绝一方作弊?

假设诸葛亮想要作弊, 那他必须在收到曹操的所有信息之后再发送 (r, z) 。现在假设诸葛亮想把自己的出拳改成 m' , 那么他必须找到另一个随机数 r' , 满足

$f(r, m) = f(r', m')$ 。

然而! 根据对函数 f 的假设, 在有生之年诸葛亮是找不到 r' 的。所以他没有办法作弊: 任何他能

② 参考 Win 局域网登陆, 添加 SSL 保护

信息安全导论

简述 windows 访问控制技术

信息安全导论最后一题是 RSA 计算

DH 算法原理

双重签名电子信封（两分、五分简答题）

网络安全

栈溢出原理

误用检测异常检测优缺点

用 BM 算法、AC 算法、写出 “she” “shr” “her” “he” 的匹配过程

计算机网络

GBN 原理

滑动窗口机制原理

DNS 解析

计算机网络

五个选择，五个填空

3 道简答题

1.gbn 的原理

2.tcp 的滑动窗口机制原理

3.dns 递归查询 www.xyz.com 的过程

1 道计算题

距离向量算法的应用

1 道设计题

设计一个简单的，可靠地，类似于 ftp 的文件传输协议，

要求 1：客户端登录连接到服务器

要求 2：具有查询文件列表和文件下载功能

写出消息类型与内容以及可靠传输机制

信息安全

五个选择，五个填空

3 道简答题

1.DH 的原理

2.Windows 的访问控制原理

3.电子信封的原理

1 道计算题

RSA 计算

网络安全

五个选择，五个填空

3 道简答题

1.BM 算法的应用：给一个模式和文本串，问第一次失配后，指针指向哪个字符

2.基于误用和基于异常的 IDS 的优缺点

3.堆栈类缓冲区溢出的原理以及注入码的作用

1 道计算题

AC 算法的应用

1) 给出几个模式串，写出 AC 算法的 3 个表

2) 给一个文本串，写出具体的匹配过程

20年

1、GBN的原理：在GBN中，发送端不需要在接收到上一个数据包的ACK后发送下一个数据包，而是可以连续发送数据包。在发送端发送数据的过程中，如果接收到对应已发送的某个数据包的NACK则发送端将NACK对应的某个数据包进行重发，然后再将该数据包之后的数据包依次进行重发。

2、tcp滑动窗口的原理：TCP连接每一方的接收缓冲空间大小都固定，接收端只允许另一端发送接收端缓冲区所能接纳的数据，TCP在滑动窗口的基础上提供流量控制，防止较快主机致使较慢主机的缓冲区溢出；

3、dns递归查询：

- (1) 向本地域名服务器发出dns请求报文
- (2)本地域名服务器收到请求后，查询本地缓存，若没有，则向根域名服务器发出请求
- (3)根域名服务器判断属于.com域，向顶级域名服务器dns.com发出请求
- (4)顶级域名服务器收到请求，判断属于xyz.com域，向对应的权威域名服务器dns.abc.com发出请求
- (5)权威域名服务器收到请求，将查询结果发回顶级域名服务器，依次发回直到本地主机

设计：略

信息

① DH 原理:

(1) Alice 选取大的随机数 $x < p$, 并计算 $Y = g^x \pmod{P}$ 。

(2) Bob 选取大的随机数 $x' < p$, 并计算 $Y' = g^{x'} \pmod{P}$ 。

(3) Alice 将 Y 传送给 Bob, Bob 将 Y' 传送给 Alice。

(4) Alice 计算 $K = (Y')^x \pmod{P}$, Bob 计算 $K' = (Y)^{x'} \pmod{P}$ 。

显而易见, $K = K' = g^{xx'} \pmod{P}$, 即 Alice 和 Bob 已获得了相同的秘密值 K 。双方以 K 作为加解密密钥, 以传统对称密钥算法进行保密通信。

② 电子信封原理:

SET使用电子信封来传递更新的密钥。电子信封涉及两个密钥, 一个是接收方的公开密钥, 另一个是发送方生成临时密钥, 发送方使用接收方的公钥加密临时密钥。一般将这个被加密的密钥称为电子信封, 接收方可以用私钥还原临时密钥。

流程: 发送数据者生成专用对称密钥 K_s , 将原文加密成密文, 同时使用接收方的公钥加密 K_s , 将两部分密文连接在一起传输给接收方。接收方先解密得到 K_s , 再用 K_s 解密密文。

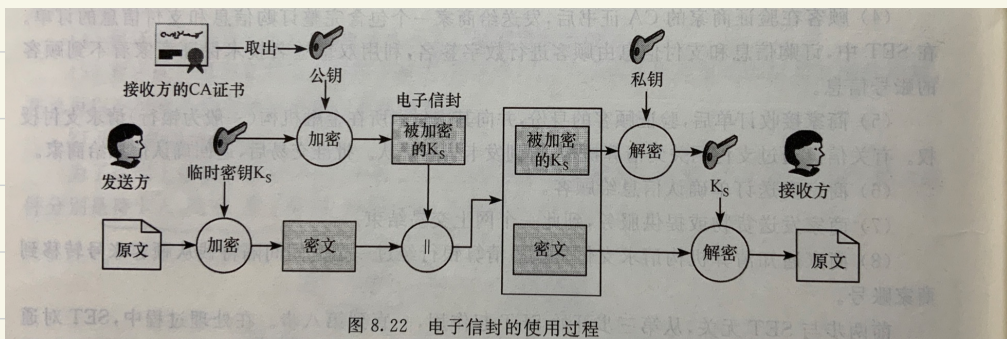


图 8.22 电子信封的使用过程

② Win访问控制原理:

Windows访问控制模块主要由访问令牌和安全描述符组成。通过访问令牌和安全描述符的内容, Windows可以确认持有令牌的访问者能否访问持有安全描述符的对象。

Windows中每个账户都有一个安全标识符。而每个访问令牌都与特定的Windows账户相关联。当账户登录时, LSA会从数据库读取账户信息, 生成访问令牌。在该账户环境下启动的进程, 都会获得该令牌的副本。访问客体时, 需要将令牌提供给SRM检查访问客体的访问控制列表, 决定是否可以进行访问。

安全描述符与每个客体对象关联, 描述客体对象的属性和安全规则, 包含SID和ACL, ACL又包含了DACL和SACL。DACL描述了允许或拒绝特定账户对对象的操作。SACL为系统审计服务。

网络安全

栈溢出原理:

栈是一种后入先出的数据结构, 大小在系统创建线程时就已分配好, 包括:一块连续的内存块、一个堆栈指针(SP)、一个基址指针(BP)、保存具有固定偏移的局部变量和函数参数的基地址。栈的增长方向是从内存高端向内存低端增长, 而大多数的内存复制是从内存低端到内存高端。

在高级语言中, 程序函数调用和函数中的临时变量都会用到栈, 参数的传递和返回值也会通过栈来实现。

栈溢出通常指程序向栈中某个变量写入的字节数超过了变量本身申请的字节数, 因而导致其与相邻的栈中的变量值被改变。通常会覆盖局部变量、ebp、返回地址、参数变量等。若覆盖了函数的返回地址, 并将该地址指向二进制代码的起始位置, 就会转而执行shellcode, 这件事是栈溢出攻击的核心。

注入码作用: shellcode一般是在目标主机上为攻击者提供远程控制的端口

基于异常和误用的优缺点:

基于误用的检测

事先定义出已知的入侵行为的入侵特征, 将实际环境中的数据与之匹配, 根据匹配程度判断是否发生了误用攻击。

优点:准确率高、误报率低

缺点:无法检测未知的攻击类型;将具体入侵手段抽象成知识具有困难;入侵特征库需要 不断维护

常用的:1、模式匹配法:将收集到的数据信息与模式数据库进行匹配。2、专家系统法: 使用IF、then的规则形式, 实现较为简单, 处理速度慢, 维护规则库复杂。3、状态迁移法:利 用状态转换图描述并检测已知的入侵模式。
基于异常检测

根据使用者的行为或资源使用状况的程度与正常状态下的标准特征之间的偏差来判断是否 遭到入侵, 如果偏差高于阈值则发生异常。

优点:通用性强, 漏报率低。

缺点:不能准确报告攻击类型。准确度不高。

常用:1、统计分析法:以统计理论为基础建立用户或系统的正常行为模式。

2、神经网络

法:采用神经网络对用户或系统活动进行监控, 将接收的事件与正常特征模型进行比较, 判断 是否出现异常。3、聚类分析法。4、人工免疫系统。

BM. AC算法总结

2021 哈尔滨工业大学 837 真题回忆版

计算机网络

- 1、FTP 数据传输使用端口 20, 控制连接 21
- 2、下列使用 TCP 协议的是: BGP
RTP、OSPF、BGP、RIP
- 3、DNS 属于应用层协议
- 4、OSI 比 TCP/IP 多了哪三层 会话层, 表示层, 数据链路层
- 5、TCP 慢启动选择、原理? 题型不明
- 6、BGP 的路径向量协议原理
- 7、DV 计算

信息安全

- 8、安全保护过程 (选择题, 选项是安全规则建立与实现 整改等)
- 9、Short 三维链表规则原理
- 10、认证函数概念
- 11、木马原理
- 12、DH 计算

网络安全

- 13、端口扫描一般不使用 (选择) 一般使用(TCP/UDP)
- 14、DNS、IP、TCP、ICMP
- 15、libcap loop 函数中 cnt 参数的含义 处理的分组数量, 为0时停止处理
- 16、KMP 算法计算
- 17、栈溢出, 给定一段程序推出被覆盖后的 eip 内容。并写出 shellcode, 实现由 jmp esp 跳板。

BGP 路径向量协议原理

边界网关协议 (BGP) 只能力求寻找一条能够到达目的网络且比较好的路由 (不能兜圈子), 并非寻找一条最佳路由。BGP 采用的是路径向量路由选择协议, 它与距离向量协议和链路状态协议有很大的区别。BGP 是应用层协议, 它是基于 TCP 的。

BGP 的工作原理如下: 每个自治系统的管理员要选择至少一个路由器 (可以有多个) 作为该自治系统的 “BGP 发言人”。一个 BGP 发言人与其他自治系统中的 BGP 发言人要交换路由信息, 需要先建立 TCP 连接 (可见 BGP 报文是通过 TCP 传送的, 也就是说 BGP 报文是 TCP 报文的数部分), 然后在此连接上交换 BGP 报文以建立 BGP 会话, 再利用 BGP 会话交换路由信息。当所有 BGP 发言人都相互交换网络可达性的信息后, 各 BGP 发言人就可找出到达各个自治系统的较好路由。

每个 BGP 发言人除必须运行 BGP 外, 还必须运行该 AS 所用的内部网关协议, 如 OSPF 或 RIP。BGP 所交换的网络可达性信息就是要到达某个网络 (用网络前缀表示) 所要经过的一系列 AS。图 4.12 给出了一个 BGP 发言人交换路径向量的例子。

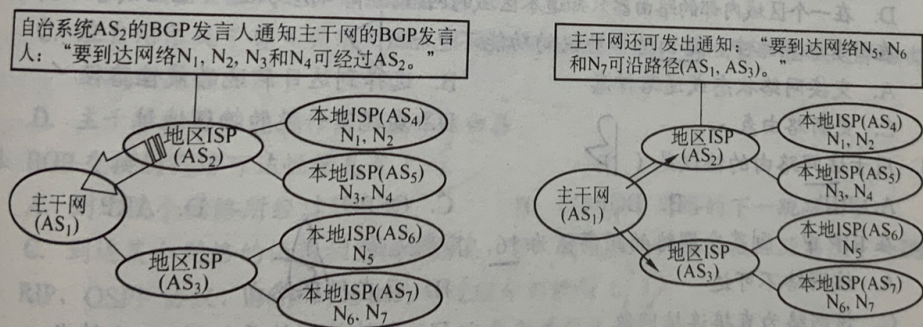


图 4.12 主干网与自治系统间路径向量的交换

BGP在路径发生变化时, 会向其他AS的邻站BGP发言人交换网络可达性信息, 即到达某个网络要经过的一系列AS。

发言时需要建立TCP连接, 在此连接上交换BGP报文以建立BGP会话, 利用BGP会话交换路由信息。包括OPEN、UPDATE、KEEPALIVE、NOTIFICATION四种报文。

工作原理如下: 每个AS至少要选择一個路由器作为BGP发言人。一个BGP发言人要与其他AS中的BGP发言人交换路由信息, 需要建立TCP连接, 在此连接上交换BGP报文以建立BGP会话, 利用BGP会话交换路由信息。当所有BGP发言人都相互交换网络可达性信息后, 各BGP发

Snort 三维规则

配,就通知输出模块进行报警。Snort 将所有已知的入侵行为以规则的形式存放在规则库中,并以三维链表结构进行组织。如图 7.20 所示,每一条规则由规则头和规则选项两部分组成。规则头对应于规则树节点(Rule Tree Node, RTN),包含规则动作选项、数据包类型、源地址、源端口、目的地址、目的端口、数据匹配内容等选项。规则选项对应于规则选项节点(Optional Tree Node, OTN),包含报警信息和项分为 Alert、Log、Pass、Activate 和 Dynamic 五类,对应五个规则链表节点(Rule List Node, RLN),每个 RLN 指向一个 RLH(Rule List Head)节点。每个 RLH 包含有四个指针,分别指向 IP、TCP、UDP 和 ICMP 四棵规则协议树。RLH 具有可扩展性,可根据需要添加规则协议树。每棵规则协议树包含一个 RTN 链表,每个 RTN 又连接一个 OTN 链表。实际上每条规则是由链表。图 7.20 中的 right 和 next 是同级指针,而 down 和 Iplist 等为从属指针。

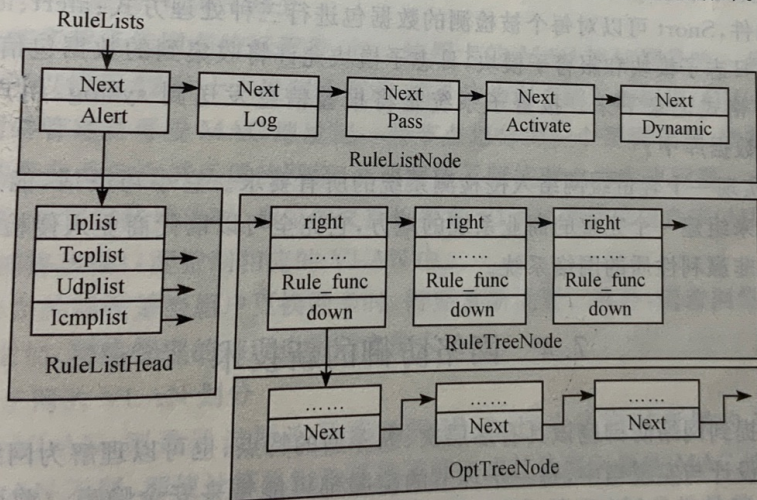


图 7.20 Snort 的三维规则链表结构

2022 年哈工大 837 网络空间安全考研试题回忆版

第一部分 计算机网络

一、选择题 (5 道, 每道 2 分, 总计 10 分)

1. () 协议用于配置 IP 地址 **DHCP**
2. 每种网络都有的一层是 (**B**)
A. 网络层 B. 传输层 C. 数据链路层 D. 应用层
3. 以下哪个协议在传输层上 (**A**)
A. UDP B. HTTP C. IP D. DNS
- 4.
5. 下列协议端口序号最小的是 ()
179 **25** **23** **80**
A. BGP B. SMTP C. telnet D. http

二、填空题 (10 空 8 道, 每空 2 分, 总计 20 分)

1. () 协议运行在 AS 之间 **BGP**
2. IPv4 数据报的首部长为 () **20B**
3. () 协议用于配置 IP 地址 (好像确实和上面的一个选择题一样) **DHCP**
4. () 协议根据 IP 地址查询 MAC 地址 **ARP**
5. 维护端与端连接的为 () 层和 () 层 **传输** **会话**
- 6.
- 7.

(注: 这两问不太记得了, 只记得它们不是计算的, 且是在大纲上那么几个方向, 比较简单, 基本上有手就行, 未写的选填空题都如此)

socket() / connect()

8、TCP 连接中用于建立和维护（貌似是这么问的）连接的 API 是（ ）和（ ）

connect() / send

三、简答题（4 道，每道 5 分，总计 20 分）

1、简述 TCP 慢启动原理过程

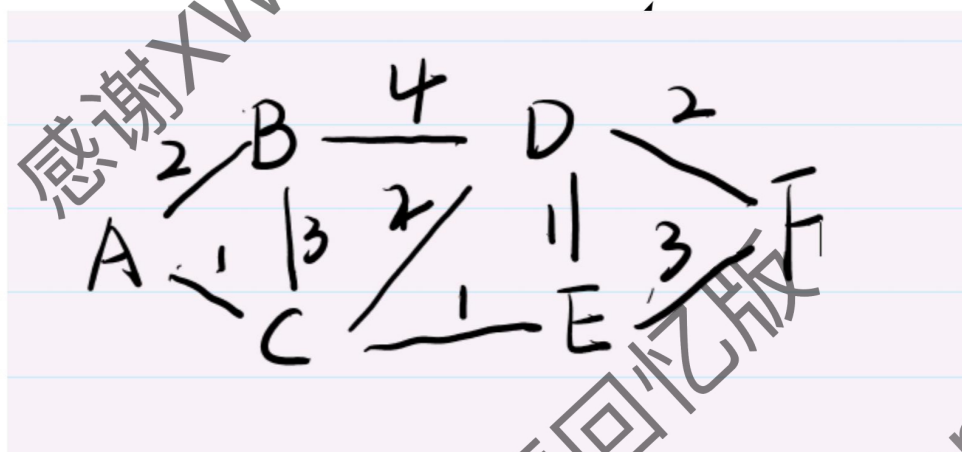
2、简述传输层功能

3、简述 DNS 资源记录的五个字段（我没记错，试题上说的就是五个，比大黑书上的多了一个）

4、简述 traceroute 利用了什么样的路由器机制

四、计算题（1 道，10 分）

一道关于链路状态 LS 算法的题，问以 B 为原点，整个拓扑的链路状态是什么，求出各点到 B 的距离，以及先后加入 N 的顺序，如 B (0 (距离), 1 (顺序)) 给出详细求解过程



第二部分 信息安全基础

五、选择题（5 道，每道 2 分，总计 10 分）

1、信息安全的三个发展阶段

通信安全 / 信息安全 / 信息保障

2、信息安全的一部法律

3、系统的脆弱性

4、SSL 协议在哪一层

传输层 (TCP/IP 于应用层之间)

5、信息安全三大原则，答案应该是 CIA，选项不太记得了

机密
完整
可用

TCP 慢启动过程

在TCP刚刚连接好并开始发送TCP报文段时，令cwnd为1，每收到一个对报文段的ACK便令cwnd加1，即经过一个RTT，cwnd加倍。直到把cwnd增大到慢开始门限sssthresh。再使用拥塞避免算法。这样可使分组注入网络是速率更合理。

慢开始的慢并不是指cwnd的增长速率慢，而是指一开始将cwnd设置为1，再逐渐增大cwnd。

出现三种事件会结束慢开始：1、出现超时。2、到达慢开始门限。3、检测3个冗余ACK。

② 传输层的功能

负责进程之间的通信服务，提供端到端的传输服务，提供流量控制，差错控制，分用与复用的功能。

③ DNS五元组 (Name, Value, Type, TTL, class)

④ Traceroute

Traceroute可以用来定位到目标主机上之间所有的路由器。

原理：1、试图用最小的TTL发出探测包来跟踪数据流到达目标主机所经过的网关，然后监听来自ICMP的应答。

2、程序利用TTL实现功能，每当数据包经过一个路由器，TTL就会减一。当存活时间是0时，主机便利用ICMP发送超时的报文。

四、总结

六、简答题（5 道，每道 5 分，总计 25 分）

- 1、一个密码体系必须满足哪些特性
- 2、弱无碰撞特性指的是什么
- 3、简述一下 Windows 系统域登录时进行的身份认证过程
- 4、DES 的明文、密文、密钥、子密钥位数，他的安全性依赖于何物
- 5、简述网络层安全协议抗重放攻击原理

七、计算题（1 道，总计 10 分）

一道 RSA 计算题，Alice 和 Bob（生日为 3 月 4 号），Alice 的公钥为 $\{7, 55\}$ ，Bob 的公钥为 $\{7, 33\}$ ，Alice 向 Bob 发送了内容为 2 和 1 的密文，他们分别对应 Alice 生日的月日，此密文既可认证又保证安全，问 Alice 的生日是多少？

第三部分 网络安全基础

八、选择题（5 道，每道 2 分，总计 10 分）

- 1、python 网络爬虫是主动攻击还是被动攻击

主动攻击（信息收集） } P13.

- 2、主动攻击易（ ），难（ ）；被动攻击易（ ），难（ ）

A

A. 检测 阻止 阻止 检测

B. 阻止 检测 检测 阻止

C. 检测 阻止 检测 阻止

D. 以上都不是

- 3、SYN Flood 攻击是什么攻击

B

A. 缓存区溢出攻击

B. DOS

C. 网络扫描

4、

5、

六、简答题

1. 系统即使达不到理论上不可破解，也应当在实际上不可破解的：系统的保密性不依赖于加密体制或算法的保密，而依赖于密钥的保密：加密算法和解密算法适用于密钥空间中的所有元素：密码系统既易于实现也便手使用。
2. 在消息特定的明文空间 X 中，给定消息 $x \in X$ ，在计算上几乎找不到不同于 x 的 $x' \in X$ ，使 $h(x) = h(x')$
3. 用户首先激活Winlogon窗口，输入用户名和口令，然后向域控制器发送登陆请求，同时计算出口令散列，口令及其散列不包含在登陆请求中，域控制器收到登陆请求后产生一个8字节的质询并发给客户端，同时取出用户的口令散列，并用口令散列对质询进行散列计算，得到质询散列。客户端收到8字节质询时，首先使用前边的计算得到的口令散列对此质询进行散列，得到质询散列，随后把此质询散列发回给域控制器。域控制器比对计算出的质询散列和客户端回送的质询散列，如果一致则登陆成功，如果比对不成功，同时向用户发送认证结果。
4. 明文长度64位一组；16轮加密完成一次des；密钥的原始长度位64，除去奇偶校验后是56位，子密钥长度8位二进制数，安全性依赖于密钥的保密性，强度来源于密钥序列的随机性和不可预测性
5. IPSec为了抵御防重放攻击，在SA中定义了序号计数器和抗重放窗口。
序号计数器:提供了设置IPSec包中序列号域的值。当SA建立后，发送方将初值置0，每发送一个包，计数器加一并置于序列号域，直至2的32次方减一。如需提供抗[?]放攻击服务，则发送方不运行重复计数，一达到2的32次方，就产生新的SA
抗[?]放窗口:实际上就是某个特定时间接收到的数据包序号是否合法的上下界，同时窗口具有滑动功能。收到数据包后，当序号sn在窗口左侧，为重放攻击。在窗口内，检查序列号相应位置是否已标记，若未，则接收，标记了，则为重放攻击。在窗口右侧且通过mac认证，窗口需要向右滑动并标记序列号位置。

七 计算题

① 即认证又保证安全. $\Rightarrow$ 私钥加密, 公钥认证.

B: 3月4日

$$\begin{array}{l} A \{7, 55\} \\ B \{7, 33\} \end{array} \Rightarrow \text{私钥} \left\{ \begin{array}{l} A \{d_1, 55\} \\ B \{d_2, 33\} \end{array} \right. \quad \begin{array}{l} A \{23, 55\} \\ B \{3, 33\} \end{array}$$

$$d_1: 55 = 5 \times 11$$

$$\varphi(55) = 4 \times 10 = 40$$

$$d_1 \cdot 7 \bmod 40 = 1$$

$$\Rightarrow d_1 = 23$$

$$\begin{array}{l} \textcircled{1} d_1 \cdot 7 - 40k = 1 \quad k=4 \quad d=23 \uparrow \\ \textcircled{2} d_1 \cdot 7 - 5k = 1 \quad d=3 \quad k=4 \\ \textcircled{3} 2d_1 - 5k = 1 \quad k=1 \quad d_1=3 \\ \textcircled{4} 3d_1 - k = 1 \quad k=1 \quad d_1=1 \\ \text{全 } d_1=1 \Rightarrow k=1 \end{array}$$

$$d_2: 33 = 3 \times 11$$

$$\varphi(33) = 2 \times 10 = 20$$

$$d_2 \cdot 7 \bmod 20 = 1 \quad (\text{车辰轩推荐法})$$

$$d_2 = -3$$

$$\begin{array}{l} \textcircled{1} d_2 \cdot 7 - 20k = 1 \quad k=1 \quad d=3 \\ \textcircled{2} d_2 \cdot 7 - 6k = 1 \quad d=1 \quad k=1 \\ \textcircled{3} d_2 - 6k = 1 \\ \text{全 } k=0 \quad d=1 \end{array}$$

$$A \xrightarrow{\text{月日} (2,1)} B$$

① $\left\{ \begin{array}{l} 2 \text{ 加密} \rightarrow 2 \text{ 使 } B \text{ 公钥加密} \\ 1 \text{ 认证} \rightarrow 1 \text{ 使 } A \text{ 私钥加密} \end{array} \right.$

② $\left\{ \begin{array}{l} 2 \text{ 认证} \rightarrow 2 \text{ 使 } A \text{ 私钥加密} \\ 1 \text{ 加密} \rightarrow 1 \text{ 使 } B \text{ 公钥加密} \end{array} \right.$

$A(x, y) \text{ 命题}$

$$\textcircled{1} \quad 2^3 \bmod 33 = 8$$

$$1^3 \bmod 55 = 1$$

8月1日

$$\textcircled{2} \quad 2^7 \bmod 55 = 18$$

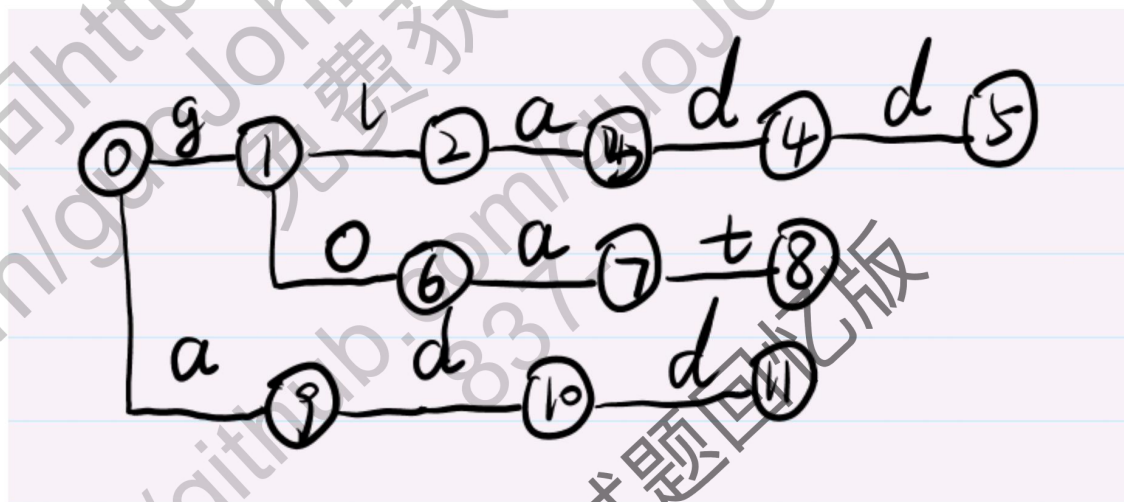
$$1^3 \bmod 33 = 1$$

18月1日 (不符合)

(注: 4, 5 感觉和考纲没有关系, 是真的有手就行)

九、简答题 (3 道, 每道 5 分, 总计 15 分)

1、AC 算法, gladd, goat, add, 指出 $f(9)$ 的输出, 输出函数 $output(5)$ 的输出



2、DNS 欺骗原理

3、网卡数据捕获原理

十、计算题 (2 道, 每道 10 分, 总计 20 分)

1、题目给出 TCP 报文结构, seq 和 ack 以及报文 len, 问如果攻击者想中断 TCP 连接, 则发送的报文中

(1) 需要修改哪个标志位, 修改成什么

(2) seq 是什么

(3) ack 是什么

2、WM 算法题, 具体是什么我忘了, 给出一个包含三个模式的模式集和一个文本, 每次检测两位, 问第一次匹配后, 指针在哪, 需要给出具体的 shift 表和过程。(和此链接中的差不多, 只是具体模式集和文本不一样, 其他都一样, 模式集的个数是一样的, 最短长度也一样) [浅谈 WM 算法 - IvanB.G.Liu - 博客园 \(cnblogs.com\)](https://github.com/guoJohnny/837-免费获取)

后记: 由于考完那天和室友一同喝酒, 我便忘了回忆, 等过了几天才想起来。以上这些已是我的极限

2. DNS欺骗基本原理是利用冒充域名服务器，把受害者要查询的域名对应的IP地址伪造成欺骗者希望的IP地址，这样受害者就只能看见攻击者希望的网站页面。

其主要分为监听式主机欺骗和DNS服务器污染:

- 1、监听式主机欺骗:监听受害者的DNS请求信息，伪造DNS响应信息发送给受害者，使受害者无法访问正确网络。
- 2、DNS服务器污染:欺骗者伪造DNS查询过程，欺骗DNS服务器，使其以错误的域名信息添加或更新原内容，无法提供正确的域名服务。

3. 网络数据包捕获机制捕获整个网络的数据流量并进行过滤，将感兴趣的信息发送给上层。通常使用sniffer。

Sniffer需要将网卡设置为混杂模式，其工作在网络环境的底层，拦截所有网络上正在传送的数据，并通过相应软件处理，实时分析数据内容。在共享环境下，数据传输是通过广播实现的，应用程序只能响应与自己硬件地址匹配或是广播的数据帧，无法接受与自己无关的数据帧。因此需要将网卡设置为混杂模式，接受目的地地址不是自身的数据包，然后直接访问数据链路层，获取数据并交于上层过滤处理。可使用 libpcap或winpcap等。

在交换式网络环境中，网络设备无法监听其他端口和其他网段的数据。可采用如下方法: 1、将捕获程序放在网关上。2、进行端口映射。3、在交换机与路由器之间连接hub。4、实行ARP欺骗。

十.
①

1. 设置RST标志位可以强制中断链接；或者设置FIN标志位为1进行四次挥手。

2. seq (Sequence Number) : 32bits, 表示这个tcp包的序列号。tcp协议拼凑接收到的数据包时, 根据seq来确定顺序, 并且能够确定是否有数据包丢失。

ack (Acknowledgment Number) : 32bits, 表示这个包的确认号。首先意味着已经收到对方了多少字节数据, 其次告诉对方接下来的包的seq要从ack确定的数值继续接力。

② 略